

Auth & Session Security Analyzer

Rapport d'audit de securite Android

Application analysee : dvba
Type d'authentification : JWT
Vulnerabilites detectees : 58
Date d'analyse : 18/05/2026 01:13

Score global de securite : 0 / 10 (CRITIQUE)

1. Resume Executif

Ce resume presente les principales vulnerabilites identifiees lors de l'audit, evalue le niveau de risque global et formule les recommandations prioritaires.

L'application Android analysee implemente un mecanisme d'authentification par JWT presentant des vulnerabilites critiques qui compromettent gravement la securite des utilisateurs et des donnees sensibles. Les principaux risques identifies sont l'absence de validation d'expiration des tokens JWT, permettant une utilisation indefinie des sessions, l'impossibilite d'invalider les tokens apres deconnexion autorisant des attaques par rejeu, et le stockage en clair des tokens dans SharedPreferences sans chiffrement. S'ajoutent a cela des secrets codes en dur dans le code source, l'exposition de donnees sensibles dans les logs applicatifs, et l'utilisation de communications HTTP en clair, augmentant le risque d'interception par attaque man-in-the-middle. Ces vulnerabilites permettent a un attaquant d'usurper l'identite d'utilisateurs legitimes, d'accéder a leurs comptes apres deconnexion, ou d'intercepter les tokens en transit. Les trois recommandations prioritaires sont : (1) implémenter immédiatement la validation obligatoire du champ 'exp' et une invalidation cote serveur des tokens lors de la deconnexion, (2) migrer le stockage des tokens vers EncryptedSharedPreferences ou Android Keystore avec chiffrement fort, et (3) eliminer tout stockage de secrets en dur et desactiver les logs contenant des donnees sensibles.

2. Analyse Statique - Vulnerabilites detectees

L'analyse statique consiste en la decompilation de l'APK avec JADX et l'examen des sources Java/Kotlin par patterns regex. Les resultats sont classes par severite : **CRITIQUE** (-3 pts), **ELEVE** (-2 pts), **MOYEN** (-1 pt).

Fichiers analyses : 1165 | Vulnerabilites : 32 | Score : 0/10

Severite	Type	Fichier	Detail
ELEVE	Identifiants dans les logs	a.java	Log.e(str, "Failed to check device credential. Parent handler not f...
ELEVE	Identifiants dans les logs	a.java	Log.e(str, "Failed to check device credential. KeyguardManager n...
ELEVE	Identifiants dans les logs	a.java	Log.e(str, "Failed to check device credential. KeyguardManager ...
ELEVE	Identifiants dans les logs	a.java	Log.e(str, "Failed to check device credential. Got null intent from ...
MOYEN	Communication en clair (HTTP)	a.java	http://s
ELEVE	Identifiants dans les logs	DeviceCredentialHandler...	Log.e("DeviceCredentialHandler", "onCreate: Executor and/or call...
ELEVE	Identifiants dans les logs	DeviceCredentialHandler...	Log.e("DeviceCredentialHandler", "onActivityResult: Bridge or call...
CRITIQUE	Secret code en dur	b.java	password: "); sb.append(this.f864a.isPassword()); sb.a...
ELEVE	Token dans SharedPreferences	h.java	getSharedPreferences("jwt", 0).getString("accesstoken
ELEVE	Token dans SharedPreferences	i.java	getSharedPreferences("jwt", 0).getString("accesstoken
ELEVE	Token dans SharedPreferences	t.java	getSharedPreferences("jwt", 0).getString("accesstoken
ELEVE	Token dans SharedPreferences	w.java	getSharedPreferences("jwt", 0).getString("accesstoken
ELEVE	Identifiants dans les logs	a1.java	Log.d("GetTokenResponse", "Failed to read GetTokenResponse ...
ELEVE	Identifiants dans les logs	a1.java	Log.d("GetTokenResponse", "Failed to convert GetTokenRespon...
CRITIQUE	Secret code en dur	n1.java	secret="); sb.append(this.i); sb.append("
ELEVE	Identifiants dans les logs	i.java	Log.e(aVar.f1410a, aVar.a("Error parsing token claims", new Obj...
ELEVE	Token dans SharedPreferences	j.java	getSharedPreferences("com.google.firebase.auth

ELEVE	Identifiants dans les logs	k.java	Log.e(aVar2.f1410a, aVar2.a("Unable to decode token", new Obj...
ELEVE	Token dans SharedPreferences	n.java	SharedPreferences.Editor editorEdit = context.getSharedPreferen...
ELEVE	Token dans SharedPreferences	n.java	SharedPreferences.Editor editorEdit = context.getSharedPreferen...
ELEVE	Token dans SharedPreferences	p.java	getSharedPreferences(String.format("com.google.firebase.auth
ELEVE	Token dans SharedPreferences	AddBeneficiary.java	getSharedPreferences("jwt", 0).getString("accesstoken
ELEVE	Token dans SharedPreferences	ApproveBeneficiary.java	getSharedPreferences("jwt", 0).getString("accesstoken
ELEVE	Identifiants dans les logs	BankLogin.java	Log.d("accesstoken", string)
ELEVE	Token dans SharedPreferences	BankLogin.java	SharedPreferences sharedPreferences = BankLogin.this.getShar...
ELEVE	Token dans SharedPreferences	BankLogin.java	sharedPreferences.edit().putString("accesstoken
ELEVE	Token dans SharedPreferences	Dashboard.java	SharedPreferences.Editor editorEdit = getApplicationContext().ge...
ELEVE	Token dans SharedPreferences	Myprofile.java	getSharedPreferences("jwt", 0).getString("accesstoken
ELEVE	Token dans SharedPreferences	ResetPassword.java	getSharedPreferences("jwt
ELEVE	Token dans SharedPreferences	ResetPassword.java	getSharedPreferences("jwt", 0).getString("accesstoken
ELEVE	Token dans SharedPreferences	SendMoney.java	getSharedPreferences("jwt", 0).getString("accesstoken
ELEVE	Token dans SharedPreferences	ViewBalance.java	getSharedPreferences("jwt", 0).getString("accesstoken

3. Analyse Dynamique - Tests d'authentification

L'analyse dynamique evalue le comportement de l'application en cours d'exécution. Les tests portent sur la validité des tokens après déconnexion, la durée de vie, la rotation des tokens, la fixation de session et la robustesse du mécanisme d'authentification.

Mode d'analyse :	API_DIRECT
Déconnexion effective :	Non (VULNERABLE - rejeu possible)
Durée de vie du token :	None min
Rotation des refresh tokens :	Non teste

Vulnérabilités détectées lors des tests :

CRITIQUE	Le token JWT ne contient pas de champ 'exp'
CRITIQUE	HTTP 200 après logout - invalidation absente
CRITIQUE	

4. Cookie Security Scanner (OWASP)

Analyse des headers HTTP Set-Cookie interceptes via mitmproxy. Verification des 7 controles OWASP : flag HttpOnly (MASVS-NETWORK-2), flag Secure (MASVS-NETWORK-1), attribut SameSite (protection CSRF), Max-Age/Expires, restriction de domaine et prefixes __Host-/__Secure-.

Cookies interceptes : 0 | Findings : 1 | Score : 10/10

Severite	Probleme	Correction recommandee
INFO	Fichier de trafic introuvable	

5. Android Storage Scanner (SharedPrefs / Keystore)

Audit du stockage des donnees sensibles dans le code source decompile. Verification de l'usage de Android Keystore, EncryptedSharedPreferences, et detection des tokens stockes en clair (MASVS-STORAGE-1 et STORAGE-2).

Findings : 19 | Score : 0/10 | EncryptedSharedPreferences : NON | Android Keystore : NON

EncryptedSharedPreferences	NON
Android Keystore	NON

Severite	Type	Fichier	Fix recommande
ELEVE	Données sensibles dans les logs	a.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	a.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	a.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	a.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	DeviceCredentialHandl...	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	DeviceCredentialHandl...	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	w.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	w.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	w.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	w.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	e.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	k.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	a1.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	a1.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	i.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Données sensibles dans les logs	k.java	Supprimer tout Log contenant des données d'auth en production (Build...
CRITIQUE	Token dans SharedPreferences non ...	BankLogin.java	Remplacer par EncryptedSharedPreferences (AndroidX Security).
ELEVE	Données sensibles dans les logs	BankLogin.java	Supprimer tout Log contenant des données d'auth en production (Build...
ELEVE	Absence d'Android Keystore	- (non détecté dans le...	Supprimer tout Log contenant des données d'auth en production (Build...

6. Session Security Scanner (Entropie / Fixation / Timeout)

Tests de securite de session cote serveur : analyse de l'entropie du Session ID (MASVS-AUTH-1), test de fixation de session (MASVS-AUTH-3), timeout d'inactivite (MASVS-AUTH-2), et invalidation post-deconnexion.

Mode : SESSION_SCANNER | Session ID : Non detecte | Findings : 1

Severite	Probleme	MASVS	Correction
INFO	Session scanner non applicable		L'application utilise JWT, pas de session cookie.

7. Scores MASVS par Domaine

Les scores reflètent le niveau de sécurité par domaine OWASP MASVS v2. Chaque vulnérabilité déduit des points selon sa sévérité. Un score inférieur à 4 indique un risque critique sur ce domaine.

MASVS-AUTH		0/10
MASVS-STORAGE		0/10
MASVS-CRYPTO		10/10
MASVS-NETWORK		9/10
Cookie Security		10/10
Storage Security		0/10

8. Checklist de Sécurité (MASVS)

Checklist générée par IA (Claude) adaptée au type d'authentification détecté. Chaque contrôle est mapé à un chapitre OWASP MASVS pertinent. Ces points constituent le référentiel de vérification pour la revue de code.

- [] [MASVS-AUTH-1-1] Implémenter une validation stricte de l'expiration JWT avec vérification du champ 'exp' | Sévérité: CRITIQUE | CWE: 613
- [] [MASVS-AUTH-1-2] Invalider les tokens JWT côté serveur après déconnexion (blacklist ou token revocation) | Sévérité: CRITIQUE | CWE: 613
- [] [MASVS-AUTH-2-1] Implémenter la rotation automatique des tokens JWT avec refresh token sécurisé | Sévérité: ÉLEVÉ | CWE: 384
- [] [MASVS-AUTH-3-1] Prévenir le jeu de tokens en validant les claims (iat, jti, nonce) | Sévérité: CRITIQUE | CWE: 294
- [] [MASVS-STORAGE-1-1] Migrer le stockage des tokens JWT de SharedPreferences vers EncryptedSharedPreferences | Sévérité: ÉLEVÉ | CWE: 922
- [] [MASVS-STORAGE-2-1] Chiffrer les données sensibles stockées localement (tokens, secrets) avec Android Keystore | Sévérité: ÉLEVÉ | CWE: 312
- [] [MASVS-STORAGE-3-1] Désactiver tous les appels Log.d(), Log.e() contenant des tokens ou identifiants | Sévérité: ÉLEVÉ | CWE: 532
- [] [MASVS-NETWORK-1-1] Forcer HTTPS pour toutes les communications (éliminer HTTP en clair) et valider les certificats | Sévérité: ÉLEVÉ | CWE: 295
- [] [MASVS-NETWORK-2-1] Implémenter la pinning de certificats pour prévenir les attaques MITM | Sévérité: MOYEN | CWE: 295
- [] [MASVS-CRYPTO-1-1] Supprimer tous les secrets codes en dur (password, secret) et utiliser Android Keystore | Sévérité: CRITIQUE | CWE: 798
- [] [MASVS-AUTH-4-1] Implémenter une stratégie de timeout de session avec revalidation périodique du token | Sévérité: ÉLEVÉ | CWE: 613
- [] [MASVS-AUTH-1-3] Valider la signature JWT avec la clé publique correcte et vérifier l'algorithme (rejeter 'none') | Sévérité: ÉLEVÉ | CWE: 347
- [] [MASVS-STORAGE-4-1] Effacer les tokens de la mémoire et SharedPreferences lors de la déconnexion | Sévérité: ÉLEVÉ | CWE: 316

9. Criteres d'Acceptation de Securite

Les criteres d'acceptation definissent les conditions que le systeme doit satisfaire pour etre considere comme securise. Ils servent de base aux tests d'acceptation, aux revues de code et aux audits de conformite MASVS.

1. Le systeme DOIT valider la presence et l'expiration du champ 'exp' dans chaque token JWT reçu avant d'accepter une requete authentifiee.
2. Le systeme DOIT implémenter une invalidation effective des tokens cotes serveur lors de la deconnexion (refuser les requetes avec ancien token apres logout).
3. Le systeme NE DOIT PAS stocker les tokens JWT en clair dans SharedPreferences ; utiliser EncryptedSharedPreferences ou Android Keystore.
4. Le systeme DOIT chiffrer tous les secrets (cles, mots de passe, tokens) stockes localement avec Android Keystore ou equivalent.
5. Le systeme NE DOIT PAS afficher de tokens, identifiants ou secrets dans les logs applicatifs (Log.d, Log.e, Log.i).
6. Le systeme DOIT utiliser exclusivement HTTPS pour la communication avec le serveur ; aucune requete HTTP en clair autorisee.
7. Le systeme DOIT implémenter une rotation automatique des tokens JWT avec generation de refresh tokens securises et validation de leur signature.
8. Le systeme NE DOIT PAS accepter les tokens JWT sans claims obligatoires (exp, iat, jti ou nonce) ou avec un algorithme 'none'.
9. Le systeme DOIT rejeter les tokens rejues apres leur expiration, independamment de leur validite cryptographique.
10. Le systeme DOIT nettoyer la memoire (effacer les tokens) lors de la fermeture de session ou de l'arrêt de l'application.